

Automotive Open Source Governance Monthly

Apr 23, 2026 5:00 PM - 6:00 PM (UTC)

Quick Recap

この会議は、自動車業界向けSBOM（ソフトウェアビルオブマテリアルズ）仕様の更新について議論するものでした。Keisuke Takase（Toyota Motor Corporation）が2月に開始した自動車SBOM活動の進捗を報告し、複数の標準や業界固有のビジネス慣行による混乱を解消するため、自動車SBOM仕様を再検討したことを説明しました。参加者から受け取ったフィードバックには、OSSとVEX管理の考慮、規制対応、AI駆動開発、独自識別子などが含まれていました。ある自動車メーカーの参加者からSPDX 2.3とCycloneDX 1.6の推奨が提案され、業界の成熟度に応じて将来的にSPDX 3.0への移行を目指すべきだとの意見が出されました。別の自動車メーカーの参加者からはVEX管理の課題が提起され、自動車SBOMがVEX情報を含めていない理由について質問がありました。参加者はGitHubやGoogle Docを通じてフィードバックを提供することが可能であることが確認されました。

Next Steps

- Ayumi: Catena-XのSBOM定義と本会議の自動車SBOM仕様の違い・類似点について、関連メンバーと連携し詳細を調査・比較し、次回以降の会議で報告する。
- Ayumi: Catena-Xに詳しいメンバーを募り、SBOM仕様の比較・検討グループを立ち上げる。
- Ayumi: SBOMフォーマット（SPDX、CycloneDX等）の推奨バージョンや範囲について、参加者やコミュニティからの意見を踏まえ議論を進め、必要に応じてドキュメントを更新する。
- Ayumi: SBOMに含めるべき脆弱性管理やVEX情報の扱いについて、参加者やコミュニティからの意見をもとに検討し、仕様案を改善する。
- Ayumi:
AI/MLモデルや商用・プロプライエタリーソフトウェアのSBOM管理、ユニークID（CPE、package URL等）の扱いについても含め、ドキュメント・仕様の拡充を進める。
- Ayumi: GitHubやGoogle Docs等へのフィードバック受付を継続し、コミュニティからのコメント・Pull Request・議論を集約・反映する。
- 関連参加者: Ayumiと連携し、自動車SBOMとCatena-X SBOM仕様のマッピング情報を提供・議論に参加する。
- ある自動車メーカー参加者: SBOM推奨フォーマット（SPDX, CycloneDX等）について自社の意見をGitHub等でフィードバックする。
- 別の参加者: 業界横断的なSBOMフォーマット推奨について意見を提供する。
- Ayumi: 機能安全、Vulnerability Management等の新たな要素についても今後ドキュメントを拡充する。

Summary

会議参加者挨拶の開始:

会議の参加者たちは、会議の開始前に挨拶を交わしました。Masatoは進行状況について言及し、Keisukeは明日になることを指摘しました。その他の参加者も挨拶をしました。

自動車SBOM更新会議:

Masatoは自動車SBOM（ソフトウェアビルオブマテリアルズ）更新についての会議を開始し、2ヶ月前にAyumiとKeisukeが提案した自動車SBOMの議論について、フィードバックや要望が得られたことを説明した。会議は複数のコミュニティ（OpenChain、AGL、Eclipseなど）を対象としたクロスコミュニティ会議であり、アンチトラストポリシーに従って実施されている。Keisukeは画面共有を行おうとしたが、接続の問題により一時的に中断された。

自動車業界SBOM活動更新:

KeisukeはToyota Motor Corporationで自動車業界向けSBOM（ソフトウェアビルオブマテリアルズ）活動について更新を提供しました。この活動は、複数の標準や業界固有のビジネス慣行による自動車業界でのSBOM実装の課題を解決することを目的としており、既存の標準（SPDX、CycloneDXなど）を参考にしながら自動車SBOMの仕様を開発しています。会議では、オープンソースソフトウェア管理の他に、商用・秘密ソフトウェアの管理にも適用可能であること、AI・機械学習モデルへの適用、脆弱性管理、規制要件、AI駆動開発によるコーディングの自動化に関するコメントが共有されました。

自動車SBOMコンセプトとCatena-X検討:

Ayumiは、自動車SBOMコンセプトとCatena-Xの違いについて欧州の関係者から質問があることを報告し、来月からCatena-Xの仕様を研究することを発表した。ある参加者は、自動車メーカーのエンジニアとしてCatena-XのSBOM交換標準の定義に参加した経験があることを共有し、双方向マッピングが既に利用可能であることを伝えた。他の参加者とMasatoは、フィードバックの提供方法について質問し、Git HubとGoogle Docsを通じて匿名でフィードバックが可能であることが確認された。

自動車SBOM形式と標準化:

ある参加者はSPDX 2.3と自動車用SPDX Liteの使用について質問し、Ayumiは自動車SBOMではどの文書形式でも良く、自動車SBOM要件をサポートする限り問題ないと回答した。Masatoは自動車SBOMの形式が定義されていないため、各OEMやサプライチェーンが最適な形式を定義することを説明し、形式よりもプロセス標準化に焦点を当てるべきだと述べた。

自動車SBOMベストプラクティス検討会議:

Masatoは自動車SBOMの取り扱いに関するベストプラクティスを共有し、継続的な更新アプローチについて説明した。ある自動車メーカーの参加者は自社の意見として、データフィールドの標準化は重要だが、SBOM形式の推奨も必要だと述べ、SPDX 2.3とCycloneDX 1.6の使用を推奨した。Ayumiは現在日本ではSPDX Liteが多用されており、制限することは難しいと回答し、SPDXのみまたはSPDXとCycloneDXの特定バージョンの使用を推奨する可能性について議論を求めた。

自動車SBOM脆弱性管理議論:

別の自動車メーカーの参加者から自動車SBOM文書について議論があり、VEX（脆弱性）管理の課題が指摘された。Ayumiは自動車システムがSBOMに脆弱性情報を含まない理由について説明し、セキュリティ情報の処理方法について議論を継続することに同意した。先の自動車メーカーの参加者は現在、業界がSBOM提供に慣れておらず、CycloneDXとSPDXの両方を推奨しているが、将来的にはSPDX 3.0への移行を目指していると述べた。さらに別の参加者は、オープンソースコンプライアンスなどの様々な分野をカバーするためのフィールド定義の必要性を強調した。